



University of Bahrain
College of Information Technology
Department of Information Systems
ITCY460 - Security Risk Assessment and Countermeasures

Group Project: Risk Management Plan

Meridian FinTech Solutions

Second Semester 2025/2026

Aljazi Ali Almujaaddam - 202202227
Dana Hussain Alhayki - 202204341
Noora Abdulrahman Bumjaid - 202203245
Nada Abdulaziz Yahya - 202203864
Maram Abdulqawi Ghaleb - 202305067

Table of Contents:

Table of Contents:	2
1. Introduction	3
2. Overview	3
3. Scope & Boundaries	3
3.1 Scope of the Risk Management Plan:	3
3.2 Boundaries of the Risk Management Plan:	4
4. Compliance Law & Regulation	4
4.1 Compliance with PCI DSS:	5
4.2 Compliance with GDPR:	5
4.3 Compliance with Anti-Money Laundering Regulations:	5
4.4 Compliance with ISO 27001:	5
4.5 Compliance with NIST SP 800-30:	5
5. Key Role & Responsibility	6
Table 1: Risk Management Plan Implementation Schedule	6
7. Risk management plan	8
7.1 Risk management approach:	8
7.2 Risk management context:	8
8. Summary	9
9. Reference	9

1. Introduction

Meridian FinTech Solutions has exposure to the risks associated with operating within a cloud-based high-speed transactional space; this includes, but is not limited to, cyberattacks, internal/insider threats, and various system vulnerabilities. The recent threat of a previous employee potentially accessing the system and an increase in business email compromise (BEC) attacks clearly demonstrate the need for a defined risk management process. Therefore, Meridian will develop a Risk Management Plan that identifies and evaluates all identified risks, prioritizes them, and develops controls to manage those risks to maintain confidentiality, ensure the integrity of information/data, and provide assurance that its systems are available.

2. Overview

Meridian Fintech Solutions is a rapidly expanding global fintech firm based in San Francisco with global offices in London and Tokyo. The company currently employs approximately 400 individuals. All employees at Meridian operate within an agile/devops framework, which allows for faster response times and greater collaboration among teams than traditional organizational structures. The company earns money primarily through transactional fees and subscription services. Some examples of the services offered include payment APIs, fraud detection, regulatory compliance tools, etc. Meridian uses Amazon Web Services (AWS) and Google Cloud Platform (GCP), both of which offer scalable platforms for supporting business continuity. Although using AWS and GCP provides many benefits, including scalability and continuity, Meridian's practice of allowing employees to bring their own devices (BYOD) and decentralized communications further increases the risk associated with managing cybersecurity.

3. Scope & Boundaries

3.1 Scope of the Risk Management Plan:

The scope of the Risk Management Plan includes risks to the cloud-based infrastructure and financial services offered by Meridian FinTech Solutions. This is because the company exclusively operates in a cloud-based environment, and therefore, the risk assessment will be conducted on systems hosted on AWS Availability Zones and the backup failover environment hosted on Google Cloud Platform. The assessment will also include critical platforms such as Pay-API, Fraud-Shield, Currency-X, Wallet-Link, Fin-Report, and Golden Record database, as they support critical financial operations and store critical transactional information. Additionally, employee access environments such as company-issued MacBooks and BYOD mobile devices will also be included. Security controls such as MFA and risks to system confidentiality, such as communication within Shadow IT, will also be included in the scope of the risk assessment.

3.2 Boundaries of the Risk Management Plan:

The scope of the Risk Management Plan will be limited to systems managed exclusively within Meridian FinTech Solutions. This means that external environments of retailers connected through Pay-API and banking systems connected to Currency-X will be outside the scope, as they will be managed by a third party. Additionally, customer-owned devices accessing Wallet-Link applications and other third-party environments not managed within Meridian FinTech Solutions will be outside the scope, as they will not be under organizational administrative control.

4. Compliance Law & Regulation

The rationale for the choice of compliance laws, regulations, and standards is based on the business model of Meridian FinTech, its international presence, and its use of a cloud platform and financial services. Based on the business presence of Meridian FinTech in the financial technology industry and the way it deals with sensitive financial and customer-related information, there are multiple compliance requirements for the company. The business processes of the company, including online payment services, fraud detection services, facilitating currency exchange, and storing customer data on a cloud platform, require compliance to ensure customer data privacy, prevent financial crimes, and ensure a secure cloud platform.

4.1 Compliance with PCI DSS:

Meridian FinTech needs to comply with PCI DSS, as it processes online payments through its service, Meridian Pay-API. PCI DSS is a security standard for organizations to ensure the secure processing of cardholder information and prevent card-not-present fraud (*Protect Payment Data With Industry-Driven Security Standards, Training, and Programs*, n.d.)

4.2 Compliance with GDPR:

Meridian FinTech needs to comply with GDPR due to its international presence and having a business office in London. As a company with international presence, it deals with the personal data of individuals within the European Union. GDPR is a regulation to protect personal data and privacy, and it imposes a penalty for non-compliance (Council of the European Union, European Parliament, 2016)

4.3 Compliance with Anti-Money Laundering Regulations:

Meridian FinTech needs to comply with Anti-Money Laundering regulations, as it provides a service, Fin-Report, for banks to automate AML filings. AML regulations are set to prevent money laundering (Financial Action Task Force, 2025, 3)

4.4 Compliance with ISO 27001:

Meridian FinTech needs to comply with ISO 27001, as it uses a cloud platform to store sensitive business and customer information. ISO 27001 helps companies manage information security risk and provides a framework for the implementation of information security controls. (ISO/IEC 27001:2022, 2022, 1)

4.5 Compliance with NIST SP 800-30:

The company needs to comply with NIST SP 800-30 for risk assessment, as described in the scenario. NIST SP 800-30 helps companies identify threats, assess risks, and implement appropriate security controls. (*NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments*, 2012)

5. Key Role & Responsibility

Senior Management: They are responsible for creating an organization's risk management policy and strategy. They will allocate a company's resources and make key decisions as to what types of risks they can accept, mitigate, or transfer.

Risk Management Coordinator / Project Manager is responsible for overseeing the development of the Risk Management Plan. The coordinator/project manager will also be responsible for implementing the plan in accordance with the project scope statement. This includes staying on track for timelines, budgets, etc. and facilitating communications between all relevant stakeholders.

IT and Security Departments are primarily responsible for identifying and assessing any technical risks that exist. They will develop and implement security measures to mitigate those risks. These include monitoring security systems to detect potential breaches, responding to security incidents that occur, specifically within AWS/GCP cloud computing environments.

Department Heads/Business Unit Managers: These individuals will support the identification of risk by Department Head/Business Unit Manager. Additionally, these managers are required to follow the organization's security policies and report any identified risks/incidents to management.

End Users/Employees: have a responsibility to adhere to the organization's security policies/procedures, especially if they use their own device (BYOD). In addition, employees/end-users should not take any actions that could potentially create new risks.

Third Party Vendor/Cloud Service Provider: are accountable for maintaining security and complying with all regulations related to the outsourcing of systems/services provided to an organization which would protect an organization's data.

6. Schedule outline

Table 1: Risk Management Plan Implementation Schedule

Phase	Activity	Description	Responsible Party	Timeline
Phase 1	Project Initiation & Planning	Define objectives, scope, and stakeholders. Establish a risk management framework.	Risk Manager / PM / Senior management	Week 1
Phase 2	Asset Identification	Identify critical assets (cloud systems, APIs, financial data, infrastructure).	IT & Security Team	Week 1–2
Phase 3	Threat Identification	Identify internal and external threats (insider threats, BEC attacks, cyberattacks).	Security Team	Week 2–3
Phase 4	Vulnerability Identification	Identify weaknesses (no SIEM, shadow IT, API key exposure).	IT & Security Team	Week 3
Phase 5	Qualitative Risk Assessment	Evaluate risks based on likelihood and impact (High/Medium/Low).	Risk Management Team	Week 4
Phase 6	Risk Prioritization	Rank risks based on severity and business impact.	Risk Manager	Week 4
Phase 7	Risk Response Planning	Define mitigation strategies (avoid, mitigate, transfer, accept).	Management & IT	Week 5
Phase 8	Control Selection	Select appropriate security controls (SIEM, API security, email protection).	Security Team	Week 5–6
Phase 9	Implementation Planning	Develop implementation steps and resource allocation.	Project Manager	Week 6
Phase 10	Risk Mitigation Implementation	Deploy controls and security solutions.	IT & Security Teams	Week 7–8
Phase 11	Business Impact Analysis (BIA)	Analyze the impact of disruptions on business operations.	Risk Team	Week 8
Phase 12	Business Continuity Planning (BCP)	Develop recovery and continuity strategies.	Management & IT	Week 9
Phase 13	Testing & Validation	Test controls, failover systems, and response plans.	IT & Security Teams	Week 10
Phase 14	Monitoring & Review	Continuous monitoring of risks and controls effectiveness.	Security Team	Ongoing
Phase 15	Reporting & Improvement	Report findings to management and update the plan regularly.	Risk Manager	Ongoing

7. Risk management plan

7.1 Risk management approach:

Meridian FinTech Solutions has implemented a systematic process for managing risk concerning its operations and asset protection. Meridian's Process includes identification of assets, which include Cloud Infrastructure (i.e. AWS), Financial Systems (e.g. accounting software), and Customer Data. Next, potential internal and external threats are identified. Following the identification of potential threats, Meridian conducts a vulnerability assessment to determine how these threats may exploit vulnerabilities in its systems. Meridian uses a Qualitative Risk Assessment methodology to assess the level of threat based on the likelihood of occurrence and the expected impact of the threat. Once assessed, Meridian selects a response strategy for each risk category as follows: Acceptance; Avoidance; Mitigation and/or Transfer of risk. Meridian views risk management as an ongoing process and requires it to be continuously monitored and improved.

7.2 Risk management context:

Meridian Fintech solutions experience risk due to potential exposures to threats that take advantage of vulnerabilities in Meridian's major assets, which can potentially lead to monetary loss, operational disruption, or reputational harm. Meridian Fintech uses major assets, including AWS/GCP Cloud Services and financial services for its customers. Meridian also has potential threats from malicious attacks from hackers, malicious employees (insider threats), and cloud service-related issues. Also, there are additional vulnerabilities with the current configuration of Meridian. Threats against Meridian's major assets could include vulnerabilities associated with the absence of a single point of entry of SIEM system; employees using their own equipment (personal devices); and the use of "hard-coded" api keys. Disruption of services would have an adverse effect on the revenue stream and customer confidence. So, maintaining Confidentiality, Integrity, and Availability (CIA) and continuously monitoring is important for Meridian.

8. Summary

The development of a well-designed Risk Management Plan will be key in helping Meridian FinTech Solutions mitigate the risks associated with both cybersecurity and operations within a rapidly evolving cloud-based financial services marketplace. A well-developed plan outlines specific objectives. The scope of what needs to be accomplished, who is responsible for the accomplishment of those objectives, identifies potential risks, and outlines how they need to be managed. This type of planning will enable Meridian to develop an understanding of its overall risk exposure through the identification of high-priority assets, vulnerabilities, and exposures; allow it to proactively respond to identified risks; support collaborative or coordinated risk management activities; provide enhanced CIA protections; improve the ability to make informed decisions about business operations; and reduce financial and operational risks.

9. Reference

Council of the European Union , European Parliament. (2016, 04 27). *General Data Protection Regulation*. General Data Protection Regulation. <https://op.europa.eu/en/publication-detail/-/publication/3e485e15-11bd-11e6-ba9a-01aa75ed71a1/language-en>

Financial Action Task Force. (2025). *PROCEDURES FOR THE FATF FOURTH ROUND OF AML/CFT MUTUAL EVALUATIONS*. Financial Action Task Force (FATF). <https://www.fatf-gafi.org/content/dam/fatf-gafi/Global-Network/FATF-4th-Round-Procedures.pdf.coredownload.pdf>

ISO/IEC 27001:2022. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO/IEC 27001:2022. <https://www.iso.org/obp/ui/en/#iso:std:82875:en>

NIST Special Publication 800-30 Revision 1, Guide for Conducting Risk Assessments. (2012, September 1). NIST Technical Series Publications. Retrieved March 30, 2026, from <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf>

Protect Payment Data with Industry-driven Security Standards, Training, and Programs. (n.d.). PCI Security Standards Council – Protect Payment Data with Industry-driven Security Standards, Training, and Programs. Retrieved March 30, 2026, from https://www.pcisecuritystandards.org/document_library/